

Lab de Pentest: Exploração de Força Bruta em Protocolo FTP

Laboratório prático focado em ataques de dicionário (*Brute Force*) via protocolo FTP, utilizando **Kali Linux** e **Medusa** em ambiente isolado. Projeto desenvolvido como parte do desafio de Cybersecurity da **DIO**.

Cenário e Infraestrutura

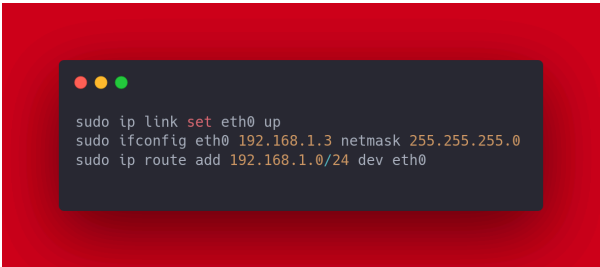
O laboratório foi montado utilizando virtualização com recursos otimizados para um ambiente de **4GB de RAM**, exigindo configurações manuais via CLI para garantir a estabilidade do sistema host (Ubuntu).

- **Atacante:** Kali Linux 2025.4 (IP: 192.168.1.3)
 - **Alvo:** Metasploitable 2 / LabSec (IP: 192.168.1.2)
 - **Rede:** Rede Interna Isolada (VirtualBox)
 - **Ferramentas:** Nmap, Medusa, FTP Client
-

Metodologia de Execução

1. Reconhecimento e Configuração de Rede

Devido a restrições de hardware, as interfaces de rede foram configuradas manualmente para evitar sobrecarga de serviços de gestão automática.



```
sudo ip link set eth0 up
sudo ifconfig eth0 192.168.1.3 netmask 255.255.255.0
sudo ip route add 192.168.1.0/24 dev eth0
```

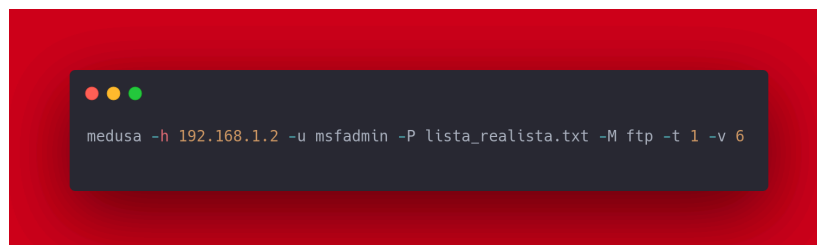
2. Scanning (Varredura)

Utilizou-se o **Nmap** para identificar serviços ativos no alvo, confirmando a porta **21/tcp** (FTP) aberta e vulnerável.



3. Ataque de Força Bruta (Medusa)

O ataque foi executado simulando um cenário de persistência, utilizando o modo *verbose* para monitorizar as tentativas de autenticação.



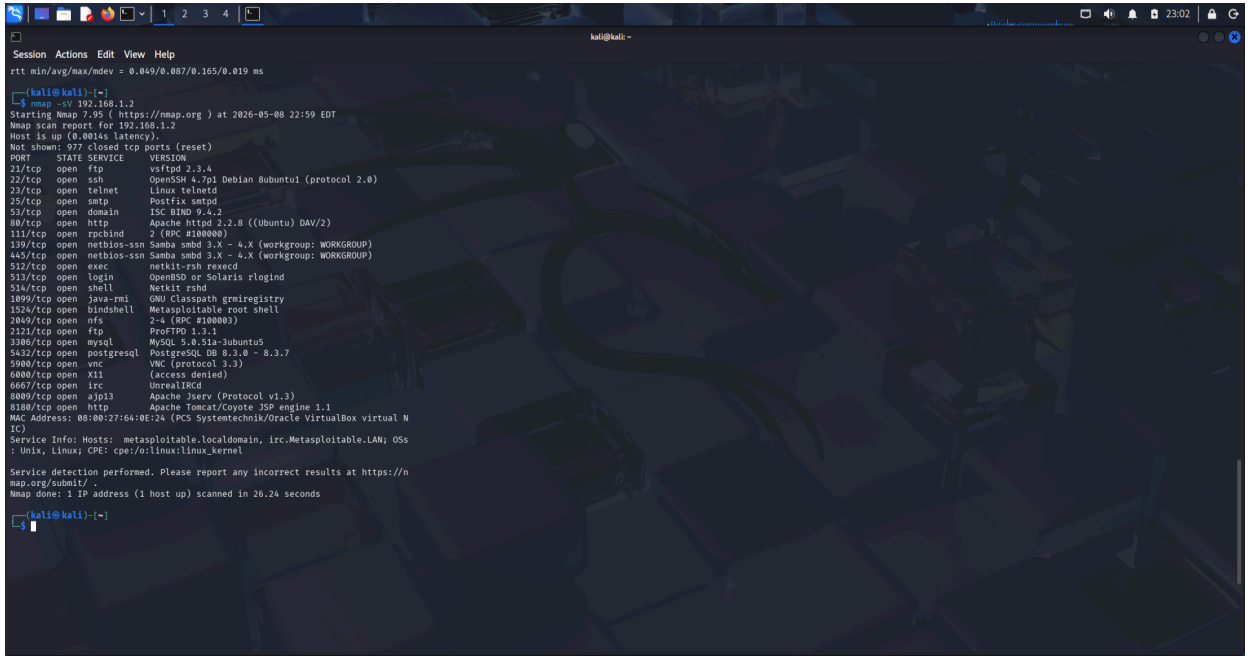
Resultado: O ataque obteve sucesso ao identificar a credencial **msfadmin:msfadmin** após múltiplas tentativas, validando a falta de políticas de bloqueio de conta.

4. Pós-Exploração

Acesso bem-sucedido ao servidor alvo para validação da quebra de credenciais, permitindo a listagem de diretórios sensíveis.

Evidências de Sucesso

Fase	Descrição
Ataque em Curso	Monitorização das tentativas de login via Medusa.
Crack Bem-Sucedido	Identificação da palavra-passe em texto claro.
Invasão Validada	Login efetuado no servidor FTP e execução de comandos ls.



[illegible]

Recomendações de Segurança (Mitigação)

Como engenheiro, a análise final foca-se na prevenção:

1. **Fail2Ban:** Implementação de bloqueio de IP após tentativas consecutivas de falha.
2. **Protocolos Seguros:** Substituição do FTP pelo **SFTP** ou **SSH**, garantindo a criptografia dos dados em trânsito.
3. **MFA:** Implementação de autenticação de dois fatores onde for possível.

Autor

Israel Cassute (Zuba)

Engenharia Informática e Comunicações

DIO Campus Expert | Especialista em DevSecOps, MLOps & NetOps | DPO